



Faculty of Engineering, Mathematics and Science

School of Computer Science & Statistics

MSc in Computer Science Hilary Term 2025 Year 1

EXAM SOLUTION NOTES

Security of Networks and Distributed Systems
CS7NS5/CSU44032

dd MMM 2025

Location

Time (2 hours)

Dr. Stephen Farrell

Instructions to Candidates:

Attempt **three** questions. All questions carry equal marks (40 each).

You may not start this examination until you are instructed to do so by the invigilator.

Materials Permitted for this examination:

N/A

Exam questions are in **bold**, like this. **Solution notes are in non-bold** Courier New, like this.

Question 1

An Irish ISP is planning to deploy an upgraded customer support chatbot for their web site using a new Large Language Model (LLM) with additional training using general company data. The chatbot will also have access to live customer data. Chatbot training and testing is to be carried out using a mixture of ISP staff and contractors. The underlying LLM requires use of the LLM provider's online service via the APIs defined for that service, but company-specific and customer data are stored in databases that are operated by the ISP. You are tasked to carry out a risk analysis to help inform the ISP of the risks they may face during training, deployment and use of the new chatbot.

You may assume any realistic setup for LLM training and runtime access. Bear in mind that your answer should be about risk analysis, risks and mitigations, and not (so much) about LLMs, so you do not need to be highly specific or accurate as to LLM details. You can also assume that the chatbot is only offered via the ISP's web site and don't need to consider other channels such as instant messaging platforms etc.

(a) Describe the process you would use to carry out this task (note: this part of the question asks about process, not the specific risks associated with the new system).

[15 marks]

The student should describe a process of identifying assets (in this case including reputation) and risks, classifying them in terms of impact and probability of occurrence, e.g. with High/Medium/Low scores for each, and assigning an overall (partial) order to the list. Normally, one then iterates, designing a mitigation for the most important item on the list, and then re-doing the analysis as necessary (since one mitigation may affect the probability of other risks or may introduce other risks). In practice, the process terminates when the available effort is expended. In this case, processes for safety checking LLMs aren't well-established so we'll allow some flexibility if the answer is sane. Any answer that captures most of this is fine, as are descriptions of equally good alternative processes.

Up to 10 marks for describing a reasonable process, 5 more for overall goodness.

(b) Describe three significant risks affecting the planned system, including their potential impact and likelihood of occurrence, and outline countermeasures you would recommend that the ISP ought apply.

[15 marks]

Up to 4 marks per risk, with 3 for overall goodness. Risks here are fairly obvious, but examples include:

- The LLM may generate bad answers that annoy users and damage the ISP's reputation
- The LLM may generate answers that ISP customers like, but that are not consistent with the ISP's business choices, e.g. a hallucinated offer or rate
- Chat messages/LLM prompts may contain sensitive customer data that could be abused by the LLM operator
- ISP corporate data and/or customer data may end up in LLM prompts and hence leak to the LLM operator
- The LLM may be attacked via other LLM instances, if training data and/or prompts are stored and re-used for "improving" the LLM
- Customers might get access to other customers' data if the overall system stores discussions
- The LLM operator APIs may be subject to DoS or other attack
- LLM operator API keys may leak
- The LLM chatbot may be better than the (presumed) backup human chat operators, leading to employee/contractor disgruntlement
- The LLM operators or contractors helping the ISP might be overly optimistic about the LLM's capabilities
- The chatbot integration with APIs for customer data might (eventually) lead to undesirable changes being made to the customer database if any "agent" capability is included
- Customers might game the LLM e.g. attempting prompt injection or whatever recent LLM attacks are discovered after the system is deployed.

(c) What risks that potentially affect end users should be considered, and what actions would you recommend be taken to mitigate those risks?

[10 marks]

5 marks/risk, assuming one or two provided, e.g.:

- Cross-customer data leakage – needs good internal API design and test
- Bad advice from LLM – needs good LLM training and perhaps some supervision, esp in early deployment
- LLM might insult customer – as above

- Frustration with human operators if LLM is better at answering and human operators don't understand – ensure human operators see previous chats and are trained to know what is good/bad from the LLM
- Customers may be lead into including more private information in prompts/chats that may leak to LLM operator – impose tight constraints on the kinds/duration of chats via the LLM

Question 2

(a) For any real Internet key exchange protocol (e.g. TLS, IPsec, or Kerberos) describe the key management and application data protection aspects of the protocol in detail. Describe how a library developer, for example the OpenSSL project for the TLS protocol, might test their implementation.

Your answer may describe any widely used version of your chosen protocol, but for TLS, you must explicitly state which version you are describing.

[25 marks]

Marks-from-15 for a good description of the scheme, with e.g. the TLS handshake and application layer properly described. 5 marks for describing possible test setups well, 5 for additional goodness (e.g. covering optional TLS extensions/tickets etc).

Historically, 95+% of students will very reasonably choose TLS and those that do not tend to be well clued-in about whatever else they pick (usually IPsec or Kerberos 'cause they've done some work on that)

(b) Outline the ways in which the security of your chosen protocol depends on other infrastructure such as the Internet routing system, the domain name system or a key management infrastructure, such as the Web-PKI for TLS as used in the web.

[10 marks]

Most protocols will depend on routing for nominal operation but (hopefully not) security; there may be privacy issues with mis-routed connections, e.g. enabling traffic analysis. Most dependencies of TLS on the Web-PKI are pretty obvious, but better if the student also describes the ACME protocol, as well as the CA. How the Web-PKI depends on the DNS, being part of that. (There is overlap between this and Q4(b), but a good student will see that and describe different things.) Getting as far as describing DNS confusables would get some extra marks as would considerations of data centre/hoster internal security.

(c) What security-relevant differences might arise for enterprises when comparing self-hosted versus cloud-hosted deployments of your chosen protocol?

[5 marks]

The main differences are the obvious ones: control vs. cost/reliability/scalability. A student might describe some

kind of hosting enclave setup for keys (such as AWS provide)
which'd get more marks.

Question 3

The Irish national health authority (the Health Services Executive, HSE) have recently (February 2025) introduced the “HSE Health App,” a mobile app for the IOS and Android platforms that allows users to access public healthcare information, but to also (for authenticated users) manage appointments with healthcare providers, store vaccination and medicine/prescription information, and with additional functions to be added over time. The app interacts with various back-end services operated by (or for) the HSE as well as with services operated by other healthcare providers (e.g. hospital groups, general practitioners). Generally, the system is a fairly typical mobile web application using APIs provided by services, with some server-server interactions in the background, but this system is dealing with highly sensitive healthcare information and is intended to eventually be used at the scale of the entire population, so security and privacy has to be a primary consideration and we can be sure the system will be attacked by various bad actors.

For the purposes of this question, assume we are back at the start of the design process and you are tasked with producing a security and privacy design for the overall system. In answering, pay attention to the marks allocated for each of parts (a)-(c) below.

(a) Outline a design for the overall system (include diagrams as appropriate), and state the security and privacy requirements the overall system should meet. Note that this part of your answer should only discuss security and privacy requirements and not describe specific mechanisms to meet those requirements.

[20 marks]

8 marks for overall design which is mostly obvious, but paying attention to server-server connections/requirements gets more; 8 marks for more obvious requirements identified, 4 more for overall goodness. Actual HSE app authentication is linked to Irish MyGovID, but students don't need to say that. Due to population-scale goal, good audit requirements should be included. Privacy requirements relatively obvious but telemetry should be considered (and totally opt-in hopefully), for security, use of API keys at population scale likely ineffective, otherwise usual mobile web app + servers stuff (e.g. DDoS resilient).

As usual some students will mix up requirements & implementation/mechanisms (i.e. parts (a) & (b)) but I'll be lenient on that.

(b) Describe, in detail, the security and privacy mechanisms you would propose for the system to meet requirements related to the handling appointments from part (a).

[15 marks]

Marks from 10 for workable and privacy-friendly answers, or, for good justification of less privacy-friendly answers, with 5 more for inclusion of less obvious things. Less obvious things might include:

- privacy preserving metrics (ppm etc.) for telemetry
- better than typical location services, e.g. “nearby health facilities” provided via bulk download without exposing current location to services at all
- use of “wallet” services on mobile platforms for better protection of on-device data
- provision of some way for non-iOS/Android users to use services

If a student misses the “handling appointments” bit in the question and answers more generally, I’ll be lenient.

(c) If you were a motivated and well-resourced bad actor, outline how would you go about planning an attack on this system with the goal of exfiltrating user data if possible, or at least denying service to users?

[5 marks]

Good/obvious attack strategies are fine, e.g. bribe operator to expose API keys/back-end data, DDoS service endpoints, lookalike app in other app stores, etc. Less obvious/sneakier stuff is even better, e.g.

- Explore whether service APIs used by app have weaknesses after reverse engineering the app
- Supply-chain attack on SDKs/libraries used in developing the HSE app
- As a “national” app, it’s very likely some local small s/w companies will have been contracted for part of the work, so targetted attacks against those organisations would likely find a weak point

Question 4

(a) Describe in detail how DNS query resolution for typical address records works, including, at each stage, potential attacks and mitigations. How do DNSSEC related resource records affect resolver performance if/when DNSSEC is used?

[15 marks]

Marks-from-7 for a reasonable description of the stub, recursive, authoritative resolver actions with/without a cold-cache. 5 marks for documenting attacks/mitigations for each stage with e.g. a good description of DNS poisoning getting 3. 3 marks for knowing how DNSKEY etc. RRs might affect performance, maybe a bonus if they note denial-of-existence problems.

(b) Describe ways in which the Web-PKI and the DNS are intertwined, and three attacks on the DNS that affect the Web-PKI.

[15 marks]

Marks-from-6 for a reasonable description of overall Web-PKI/DNS interdependencies, more if they include e.g. use of multiple vantage points in ACME challenge checking and hosting problems with ACME TLS-SNI challenges. More marks the more this differs from answer to Q2(b). Specific DNS attacks (up to 3 marks each):

- DoS (or censorship) of authoritatives to prevent access, or more subtly, cert renewal
- Registrar attacks for domain take-over, followed by cert issuance, possibly coupled with active TLS MITM
- Localised DNS spoofing (e.g. within a country) in order to route traffic via an attacker controlled n/w for traffic analysis/censorship
- DNS attacks that aim to force use of ACME services that are attacker controlled
- (V. subtle, lots of marks if noted, even if not directly affecting Web-PKI): delay HTTPS RR answers versus A/AAAA answers and make HTTPS TTL small, sufficient that browser connections fail to make use of ECH as the ECHConfig only arrives after the TLS connection has started

(c) How do privacy issues arise in connection with the use of the DNS? How are those affected by the use of DNS-over-TLS (DoT) or DNS-over-HTTPS (DoH)? What default DNS privacy setup would you recommend for a current mobile operating system? Say why you consider that a reasonable default, and how it would affect those privacy issues.

[10 marks]

4 marks for describing privacy issues well (act of accessing name from IP at time, sets of qnames being identifying etc.). 3 marks for correctly stating the effects of DoT/DoH (with maybe a bonus if done really well, e.g. noting that there are displacement issues at play) and 3 marks for a well justified non-crazy default, which may well be Do53 'cause DoT as an OS default does imply some failure cases we might not yet be willing to bear.